

NAMA : KEREN SANDRA SUDARTA
NIM : 2024071031

PRAKTIKUM 12 SECURE SDLC AND THREAT MODELING

1. DESKRIPSI SISTEM

Sistem yang dipilih pada praktikum ini adalah sistem E-Commerce, yaitu platform belanja online yang memungkinkan pengguna untuk melakukan registrasi akun, login, mencari produk, menambahkan produk ke keranjang belanja, melakukan checkout, dan melakukan pembayaran secara digital.

2. DAFTAR ASSET

Komponen	Keterangan
Nama Sistem	E-Commerce Platform
Tujuan Sistem	Memudahkan pengguna untuk berbelanja produk secara online, mulai dari pencarian produk hingga pembayaran.
Fitur Utama	Registrasi, Login, Pencarian Produk, Keranjang Belanja, Checkout, Pembayaran
User Utama	Pembeli (Customer), Penjual (Merchant), Admin Platform
Komponen Sistem	Mobile/Web App, API Server (Backend), Database, Payment Gateway, CDN

Berikut adalah daftar asset penting dalam sistem E-Commerce yang harus dilindungi

No	Asset	Mengapa Penting?
1	Data Pelanggan (Nama, Email, Alamat)	Berisi informasi pribadi yang bersifat sensitif. Jika bocor, dapat menyebabkan pencurian identitas dan melanggar privasi pengguna.
2	Data Pembayaran (Kartu Kredit, Rekening)	Berkaitan langsung dengan aset finansial pengguna. Kebocoran data ini dapat menyebabkan kerugian finansial yang signifikan.
3	Akun Pengguna (Username & Password)	Digunakan sebagai autentikasi masuk ke sistem. Jika dikompromikan, attacker dapat mengambil alih akun dan melakukan transaksi ilegal.
4	Riwayat Pesanan & Transaksi	Merupakan bukti aktivitas jual beli. Manipulasi data ini dapat menyebabkan sengketa dan kerugian bisnis.

5	Token Session / JWT	Digunakan untuk menjaga sesi login pengguna. Jika token dicuri, attacker dapat berpura-pura sebagai pengguna tanpa perlu password.
6	Database Server	Menyimpan seluruh data sistem. Akses ilegal ke database dapat mengekspos semua informasi pengguna dan transaksi.
7	API Key & Kredensial Pihak Ketiga	Digunakan untuk mengintegrasikan layanan seperti payment gateway. Kebocoran API key dapat disalahgunakan untuk transaksi tidak sah.

3. ATTACK SURFACE

Berikut adalah titik-titik masuk yang dapat dimanfaatkan oleh attacker untuk menyerang sistem E-Commerce:

No	Attack Surface	Potensi Masalah
1	Form Registrasi & Login	Rentan terhadap credential stuffing, brute force attack, dan SQL Injection jika input tidak divalidasi dengan benar.
2	API Endpoint Pembayaran	Dapat dimanipulasi untuk mengubah nominal transaksi, melakukan double spending, atau bypass verifikasi pembayaran.
3	Form Pencarian Produk	Rentan terhadap XSS (Cross-Site Scripting) dan SQL Injection melalui input pencarian yang tidak disanitasi.
4	Fitur Upload Gambar Produk	Dapat disalahgunakan untuk mengunggah file berbahaya (malware) yang dapat dieksekusi di server.
5	Endpoint Admin Panel	Jika tidak dilindungi dengan baik, user biasa dapat mengakses panel admin dan memodifikasi data sistem.
6	API Keranjang Belanja & Checkout	Rentan terhadap manipulasi harga produk, quantity, atau diskon melalui request yang dimodifikasi.

4. THREAT MODELING MENGGUNAKAN STRIDE

Analisis ancaman menggunakan framework STRIDE untuk mengidentifikasi jenis-jenis ancaman pada sistem E-Commerce:

No	Asset	Threat	STRIDE	Penjelasan Singkat
1	Akun Pengguna	Login menggunakan akun orang lain dengan credential curian	Spoofing	Attacker mencuri kredensial pengguna melalui phishing atau credential stuffing untuk mengakses akun korban.

2	Data Harga Produk	Manipulasi harga produk di keranjang belanja saat checkout	Tampering	Attacker mengubah nilai harga produk melalui modifikasi request HTTP sebelum dikirim ke server.
3	Riwayat Transaksi	Pembeli menyangkal telah melakukan pembelian yang sudah dibayar	Repudiation	Tidak adanya audit log yang memadai menyebabkan sistem tidak dapat membuktikan bahwa transaksi benar-benar terjadi.
4	Data Pelanggan & Pembayaran	Data kartu kredit dan data pribadi pengguna bocor ke pihak tidak berwenang	Information Disclosure	Data sensitif disimpan atau dikirim tanpa enkripsi, sehingga dapat diakses oleh attacker melalui man-in-the-middle attack.
5	Server Aplikasi	Server dibanjiri request palsu sehingga layanan tidak bisa diakses pengguna	Denial of Service	Attacker melancarkan DDoS attack pada saat event sale besar (misalnya Harbolnas) untuk melumpuhkan layanan.
6	Role Pengguna	Pengguna biasa mengakses fitur admin dan memodifikasi data	Elevation of Privilege	Broken Access Control memungkinkan user biasa mengakses endpoint admin untuk mengubah data produk, pesanan, atau pengguna lain.

5. ANALISIS RISIKO

Penilaian tingkat risiko dari setiap ancaman berdasarkan dampak dan kemungkinan terjadinya:

Threat	Dampak	Risk Level	Alasan
Login dengan akun curian (Spoofing)	Akun diambil alih, transaksi ilegal atas nama korban	HIGH	Berdampak langsung pada privasi, finansial, dan kepercayaan pengguna.
Manipulasi harga produk (Tampering)	Platform mengalami kerugian finansial karena produk dibeli di bawah harga sebenarnya	HIGH	Sangat merugikan merchant dan platform secara finansial, mudah dilakukan jika validasi hanya di sisi client.

Penyangkalan transaksi (Repudiation)	Sengketa antara pembeli dan penjual yang tidak dapat diselesaikan	MEDIUM	Mengganggu kepercayaan dan operasional bisnis, namun tidak selalu berdampak finansial langsung.
Kebocoran data pembayaran (Information Disclosure)	Data kartu kredit dan PII pengguna jatuh ke tangan attacker	HIGH	Melanggar regulasi PCI-DSS dan PDPA, berpotensi kena sanksi hukum dan kehilangan kepercayaan pelanggan.
DDoS pada server (Denial of Service)	Layanan tidak dapat diakses, kehilangan revenue saat periode puncak	HIGH	Serangan pada momen puncak seperti flash sale dapat menyebabkan kerugian besar dan reputasi negatif.
User biasa akses admin (Elevation of Privilege)	Manipulasi data produk, pesanan, atau pengguna lain secara ilegal	HIGH	Pelanggaran serius terhadap integritas data sistem dan kerahasiaan pengguna lain.
Upload file berbahaya via form produk	Server terinfeksi malware, eksekusi kode berbahaya	HIGH	Dapat menyebabkan kompromi total terhadap server dan seluruh data yang ada di dalamnya.

6. REKOMENDASI MITIGASI

Berikut adalah langkah-langkah mitigasi yang direkomendasikan untuk setiap ancaman yang teridentifikasi:

Threat	Risk Level	Mitigasi
Login dengan akun curian	HIGH	Implementasi Multi-Factor Authentication (MFA), hashing password dengan bcrypt/argon2, login attempt limit dengan exponential backoff, notifikasi login dari device baru.
Manipulasi harga produk	HIGH	Validasi harga selalu dilakukan di sisi server (bukan client), gunakan ID produk untuk referensi harga dari database, implementasi digital signature pada request transaksi.
Penyangkalan transaksi	MEDIUM	Implementasi audit log yang komprehensif dan tamper-proof, kirim konfirmasi transaksi via

		email dan notifikasi, simpan timestamp dan IP address setiap transaksi.
Kebocoran data pembayaran	HIGH	Enkripsi data sensitif saat transit (TLS 1.3) dan at-rest (AES-256), tokenisasi data kartu kredit melalui payment gateway bersertifikasi PCI-DSS, masking data pada log.
DDoS pada server	HIGH	Implementasi rate limiting dan throttling pada API, gunakan CDN dengan proteksi DDoS, auto-scaling infrastruktur, WAF (Web Application Firewall), dan circuit breaker pattern.
User biasa akses admin	HIGH	Implementasi RBAC (Role-Based Access Control) yang ketat, authorization check di setiap endpoint, prinsip least privilege, monitoring akses ke endpoint sensitif.
Upload file berbahaya	HIGH	Validasi tipe file (whitelist extension), scan antivirus pada file upload, simpan file di storage terpisah (bukan server utama), rename file secara acak, batasi ukuran dan format file.

7. MAPPING KE OWASP TOP 10

Pemetaan ancaman yang teridentifikasi dengan kategori OWASP Top 10 untuk konteks yang lebih luas:

Threat	OWASP Category	Alasan / Penjelasan
User biasa mengakses fitur admin	A01: Broken Access Control	Sistem gagal membatasi hak akses pengguna, memungkinkan akses ke fungsi yang seharusnya dibatasi.
Login dengan akun curian / credential stuffing	A07: Identification and Authentication Failures	Mekanisme autentikasi yang lemah tanpa MFA dan limit percobaan login memudahkan pengambilalihan akun.
Kebocoran data kartu kredit dan data pribadi	A02: Cryptographic Failures	Data sensitif tidak dienkripsi dengan benar saat disimpan maupun dikirimkan, sehingga dapat diakses oleh pihak tidak berwenang.
SQL Injection melalui form pencarian	A03: Injection	Input pengguna tidak divalidasi dan disanitasi dengan benar, memungkinkan injeksi perintah berbahaya ke database.
Upload file berbahaya ke server	A04: Insecure Design	Fitur upload tidak dirancang dengan mekanisme keamanan yang

		memadai, memungkinkan eksekusi kode berbahaya di server.
--	--	--

8. KESIMPULAN

8.1 Threat Paling Berbahaya

Ancaman paling berbahaya pada sistem E-Commerce adalah kebocoran data pembayaran (Information Disclosure) dan pengambilalihan akun (Spoofing). Kedua ancaman ini berkaitan langsung dengan data finansial dan identitas pengguna, yang dapat menyebabkan kerugian finansial besar, tuntutan hukum, dan kehancuran reputasi platform.

8.2 Asset Paling Kritis

Asset paling kritis adalah data pembayaran (informasi kartu kredit dan rekening bank) serta akun pengguna. Data pembayaran berkaitan langsung dengan uang pengguna, sementara akun pengguna menjadi gerbang utama akses ke seluruh layanan platform. Kompromi pada kedua asset ini dapat berdampak berantai pada seluruh sistem.

8.3 Mitigasi Paling Penting

Mitigasi yang paling penting dan harus diprioritaskan adalah:

- Enkripsi end-to-end menggunakan TLS 1.3 untuk semua transmisi data sensitif
- Multi-Factor Authentication (MFA) untuk semua akun pengguna
- Role-Based Access Control (RBAC) yang ketat pada semua endpoint
- Validasi input yang komprehensif di sisi server untuk mencegah Injection
- Rate limiting dan WAF untuk proteksi terhadap serangan DDoS dan brute force

8.4 Pelajaran Utama

Pelajaran utama dari praktikum ini adalah bahwa keamanan sistem bukan sesuatu yang ditambahkan setelah sistem selesai dibangun, melainkan harus diintegrasikan sejak tahap desain awal (Security by Design). Sebagai software engineer, penting untuk selalu berpikir seperti attacker sehingga kita dapat mengidentifikasi dan menutup celah keamanan sebelum sistem dieksploitasi.

Framework STRIDE membantu kita berpikir secara sistematis dan komprehensif tentang berbagai jenis ancaman yang mungkin terjadi. Sementara OWASP Top 10 memberikan konteks nyata tentang kerentanan yang paling umum ditemukan di aplikasi web dan mobile